

MID-STATE TECHNICAL COLLEGE • IT PROGRAMS

Digital Social Engineering

Unit 7 • Ethical Hacking (10-151-160)



Learning Outcomes

By the end of Unit 7 you will be able to:



Distinguish social engineering methods

Compare phishing, spear phishing, whaling, and BEC by target, technique, and goal.



Investigate social engineering tools

Use the Social-Engineer Toolkit and campaign frameworks to see how attacks are built.



Clone a target web application

Produce a credential-harvesting copy of an authorized site and explain what it captures.



Explain the value of user education

Justify awareness training as a control that changes behavior over time.



Mitigate social engineering attacks

Map defenses onto the phishing kill chain to break attacks before they reach a victim.



1

The Human Attack Surface

Why Social Engineering Dominates

Technical controls improved; attacking people became the path of least resistance.

- **Social engineering** exploits predictable human responses — trust in authority, urgency, fear, the wish to be helpful.
- No firewall rule inspects those responses, so the human is the one surface that never got patched.
- The fix is a mix of **training**, **process** (verify out-of-band), and **detection** — not a single update.



The human element

62% of breaches involved the human element in the 2026 Verizon DBIR — across 22,000+ confirmed breaches.

Pretexting now accounts for 6% of breaches, tracked separately for the first time.

The Scale of the Problem

U.S. losses reported to the FBI Internet Crime Complaint Center (IC3), 2025.

Category	2025 figure	What it tells us
Phishing / spoofing	191,561 complaints	Highest-volume attack type reported to IC3
Business email compromise	~\$3.0 billion	From only 24,768 complaints — ~\$123K each
All cybercrime losses	~\$20.9 billion	Up 26% over 2024; BEC is the #2 category

Volume vs. value: phishing is broad and high-volume; BEC is low-volume, precisely targeted, and far costlier per hit.

2

Phishing and Its Variants



One Technique, Many Shapes

The variants differ by how precisely they target the victim and what they are after.

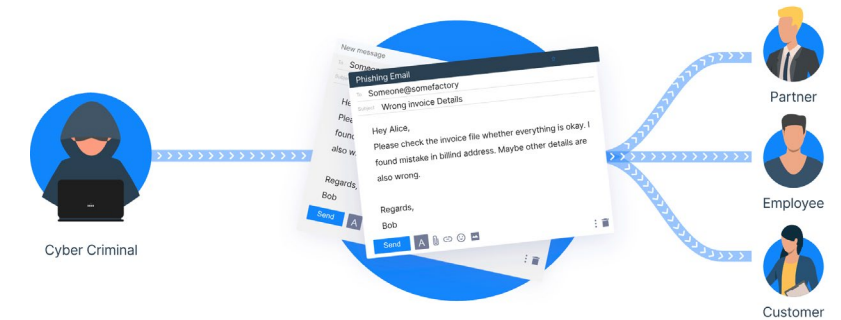
- **Phishing** — mass, untargeted lures for credentials, card numbers, or malware. Wide net, low effort.
- **Spear phishing** — tailored to a specific person or org using recon; far more convincing.
- **Whaling** — spear phishing aimed at a high-value target (CEO, CFO), where one hit pays off.
- **BEC / VEC** — compromise or spoof a real business account and redirect a payment. Often no malware at all.

Naming the variant correctly is the first defensive step — a broad credential-phish and a targeted wire-fraud attempt need different controls.

Business Email Compromise, Up Close

BEC has moved well beyond a single spoofed email.

- **Conversation hijacking** — the attacker reads a real thread, waits for a live exchange, then replies in context at the moment money moves.
- **Fabricated history** — a fresh email is seeded with an invented conversation so a cold approach looks ongoing.
- The defense is procedural: **confirm any change of payment details out-of-band** — a phone call to a known number.



A criminal inserts themselves between trusted parties to redirect funds.

Malicious Software as a Lure

Sometimes the payload is software the victim installs themselves.

- **Trojanized tools** — a legitimate-looking utility with a hidden function, e.g. a keylogger inside a "driver scanner".
- **Fake security software** — rogue antivirus that fabricates infections to extract payment or install the real payload.



SECURITY FOCUS

Users trust tools that promise to "fix" or "scan." That trust is the exploit — the download feels like the safe choice.

Why it matters: Software-installation lures bypass email filtering entirely; the user, not the attacker, delivers the payload.

3

The Economics & Kill Chain



A Low Barrier to Entry

Why phishing is everywhere: it costs almost nothing to start, and the return can be enormous.

Resource	Rough cost	Purpose
Hosting	A few \$/month	Somewhere to run the fake site
Lookalike domain	~\$10	A near-miss of a real brand name
Bulk email	Low per thousand	Send tens of thousands of lures

Even a low-cost campaign can return many thousands of dollars — which is exactly why the volume never drops.

The Phishing Kill Chain

A kill chain is the ordered set of steps an attacker moves through toward a goal.

- Attacker progression: **register infrastructure** → **send the lure** → **victim clicks** → **victim submits credentials** → **attacker acts**.
- Framing it this way matters because **every step is a chance for the defender to intervene**.
- The goal is to detect as far **"left"** as possible — ideally before a single email is sent.

LESSON 6 We return to this chain from the defensive side and place a control on every step.

4

Modern Credential Attacks



When "Turn On MFA" Is Not Enough

Today's phishing is built specifically to defeat or sidestep multi-factor authentication.

- **Adversary-in-the-Middle (AiTM)** — a reverse-proxy page relays the login in real time and steals the authenticated **session token**, carrying the MFA step along.
- **Phishing-as-a-Service (PhaaS)** — subscription kits (e.g. Tycoon 2FA, Greatness) package AiTM, hosting, and evasion for low-skill operators.
- **Device-code phishing** — abuses the legitimate OAuth "enter this code" flow; the victim grants a token with no fake site to detect.

CrowdStrike reported device-code phishing rising roughly 15-fold in the first half of 2026.

What This Changes for Defenders

If the password and the code can be relayed, protect the session itself.

- **Phishing-resistant MFA** — FIDO2 / passkeys bind the login to the real site, so a proxy cannot relay it.
- **Conditional access** — restrict sign-ins by device compliance, location, and risk score.
- **Watch for impossible logins** — a session from a new device or geography seconds after a legitimate one signals a stolen token.



The shift

Protect the **session**, not just the password.

SMS codes are better than nothing, but they are relayed just as easily as a password.



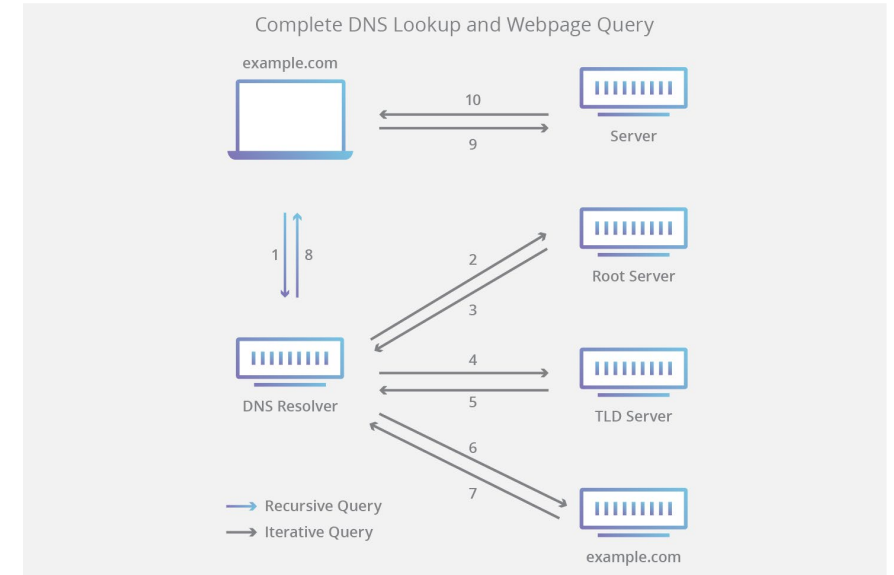
5

DNS & Proactive Detection

A DNS Refresher

Phishing usually starts with a freshly registered lookalike domain — and registration is public.

- **DNS** resolves a domain name to an IP through the resolver, root, TLD, and authoritative name servers.
- Because it must be public to work, the same data is available to **defenders**, not just attackers.
- Lookalikes take three shapes: a near-miss spelling, a brand buried in a longer string, or the same name under a different **TLD**.



Zone Files

The raw material for new-domain monitoring.

- **Zone files** are plain-text files, one per TLD, listing the domains a name server knows about.
- Each begins with a **Start of Authority (SOA)** record and holds the records for every domain in the zone.
- **ICANN CZDS** — the Centralized Zone Data Service lets approved parties request zone files for many TLDs.

```
1  yachts. 3600  in   soa   ns0.centralnic.net. hostmaster.cen
2  000000.yachts. 3600  in   ns    ns1.uniregistry-dns.com.
3  000000.yachts. 3600  in   ns    ns1.uniregistry-dns.net.
4  000000.yachts. 3600  in   ns    ns2.uniregistry-dns.com.
5  000000.yachts. 3600  in   ns    ns2.uniregistry-dns.net.
6  1097.yachts. 3600  in   ns    ns1.dnsowl.com.
7  1097.yachts. 3600  in   ns    ns2.dnsowl.com.
8  1097.yachts. 3600  in   ns    ns3.dnsowl.com.
9  111.yachts. 3600  in   ns    curitiba.porkbun.com.
10 111.yachts. 3600  in   ns    fortaleza.porkbun.com.
11 111.yachts. 3600  in   ns    maceio.porkbun.com.
12 111.yachts. 3600  in   ns    salvador.porkbun.com.
13 1232.yachts. 3600  in   ns    ns1.dynadot.com.
```

A daily CZDS feed is how a defender sees what was newly registered.

Monitoring New Domains

A four-step loop turns the daily registration feed into an early-warning signal.



Load

Pull the latest zone files — hundreds of thousands of new names appear daily.



Scan

Compare new registrations against your brand: exact-match, lookalike, and "includes" logic.



Alert

Surface the suspicious matches to an analyst for review.



Act

Investigate live ones and move to takedown or blocking — before the first email is sent.



6

Blue Team: Breaking the Chain

Controls on Every Step

No single control is enough — the goal is layered disruption across the chain.

Kill-chain step	Defensive control
Pre-phish	DNS + certificate-transparency monitoring; block domains < 30 days old; DNSTwist
Delivery	URL/attachment scanning; SPF, DKIM, DMARC; external-sender banner
Click	Awareness training that changes behavior; tie simulation results to positive incentives
Submit / act	One-click reporting; referrer monitoring; a practiced takedown process

Reporting and Takedown

Two of the highest-value, lowest-cost defenses available.

- **Human reporting is a control** — a frictionless "report phishing" button turns every employee into a sensor.
- **Takedown paths** — report the URL to browser safe-browsing services and anti-phishing groups.
- **WHOIS** — reach the hosting provider or registrar abuse contact to pull the site offline.



Inspect before you click

Hovering a link shows its real destination. Teach users to read the **actual URL**, not the friendly text.

The Finding You Cannot Remediate

A lookalike actively harvesting your customers simply moves hosts faster than you can report it.



SECURITY FOCUS

You cannot "close" this. The correct response is not a closed ticket but a **documented control requirement**: record the residual risk, brief leadership, and convert the exposure into a standing, reviewed control.

Standing controls: continuous domain monitoring, customer-facing warnings, accelerated DMARC enforcement, and a retained takedown service.

Why it matters: An unresolvable exposure that is documented and owned is managed risk; one that is forgotten is an incident waiting to happen.

Live Demo Inventory

Commands and flows demonstrated in class, in order.

- Launch SET: `sudo setoolkit` → Social-Engineering Attacks → Website Attack Vectors.
- Site cloner: choose `Credential Harvester` → `Site Cloner`, enter the Kali lab IP.
- Clone an instructor-approved login page and host it at the lab IP.
- Submit test credentials from a browser; watch the capture in the SET console.
- Read the report under `~/.set/reports/` and locate the captured username and password.



LIVE DEMO

Clear any prior run first: `rm -r ~/.set` then recreate the empty directory.

Hands-On Lab

Lab 1: Site Cloning and Credential Capture with SET.

- **Platform** — your assigned Kali VM in the course lab; authorized targets only.
- **Task** — clone an approved login page, host it, capture test credentials, and read the SET report.
- **Deliverable** — document the victim experience and name every point a defender could break the chain.



SECURITY FOCUS

Use only ASCII characters in any custom HTML — Unicode breaks SET cloning. Never clone a live third-party site or send a lure to a real person.

Why it matters: The techniques are identical to a real attack; only authorization and scope separate the lab from a felony.

Key Takeaways

-  Social engineering attacks people, not machines — and it is now the #1 way breaches start.
-  Name the variant: phishing, spear phishing, whaling, BEC. The defense differs for each.
-  Modern phishing defeats MFA — protect the session with passkeys, not just the password.
-  Zone-file monitoring turns the attacker's first step into your early warning.
-  Map controls onto the kill chain; an unfixable finding becomes a documented control, not a closed ticket.

MID-STATE TECHNICAL COLLEGE · IT PROGRAMS

Questions?

Unit 7 · Digital Social Engineering

